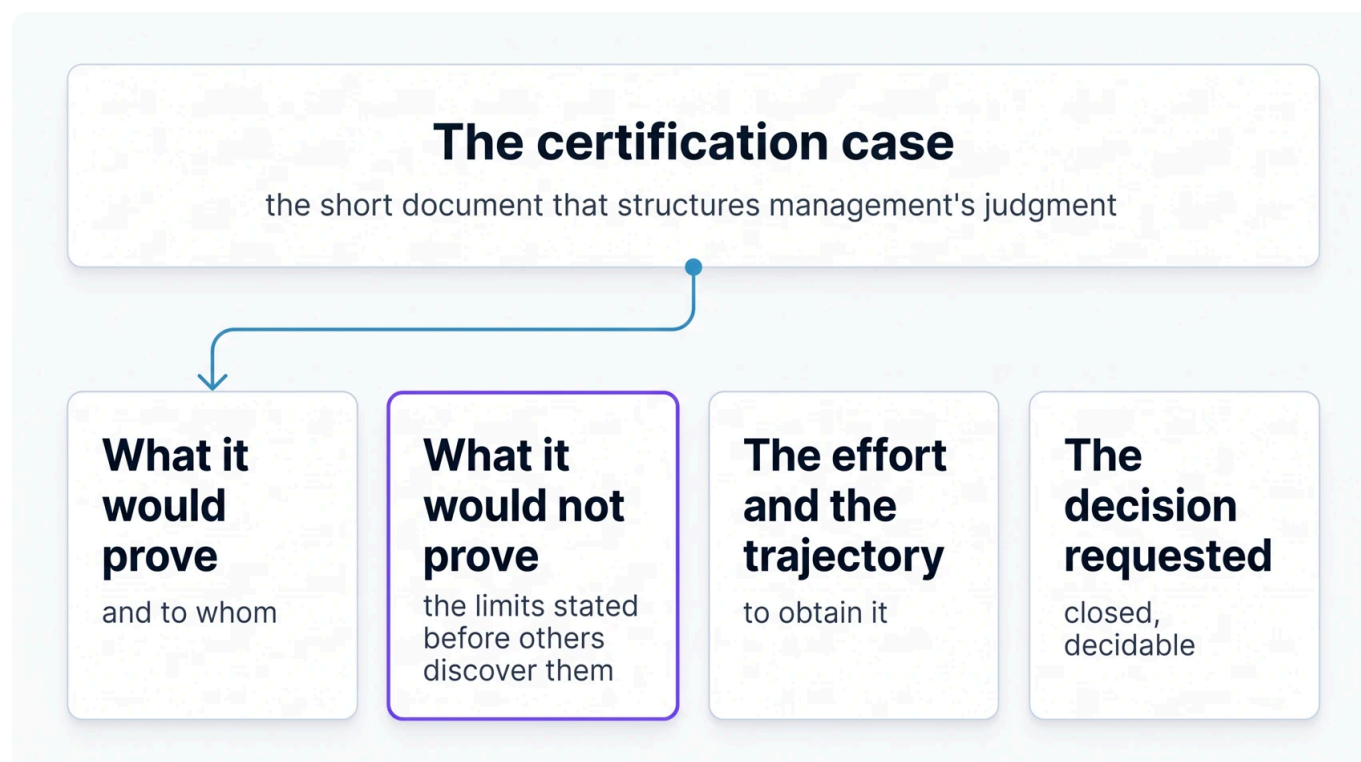


The CISO's briefing: The certification case

✓ The question that always arrives through a third party's requirement



Session objectives

By the end of this sequence:

- **Analyze** a certification requirement stated by a client, a contracting authority or an insurer, and measure its real scope
- **Build** an honest certification case: what an ISO/IEC 27001 certificate would prove for the MERIDIAN group, what it would not prove, what it would cost in effort

- **Propose** a defensible certification scope, relying on the mapping and on what session 3 established about the certificate
- **Formulate** the precise decision requested from the Executive Committee, with no unverifiable promise

Prerequisites

- Session 3: what an ISO/IEC 27001 certification attests, what it does not attest, and how to read a certificate's scope. It is the foundation of the whole sequence.
- The audit report from session 4: the deviations found per subsidiary are the raw material for evaluating the remaining path.
- The risk treatment plan and the register from session 7: the risk reduction trajectory the group has just settled.
- The governance set in session 1: the Executive Committee validates budgets, executive management sets the risk appetite, and the Group CISO (RSSI Groupe) proposes and arbitrates.

What to set down before the exercise

Two notions are enough this morning, and neither requires opening the standard, which the lecture will do anyway.

The first notion is the certification business case. The problem it solves is a problem of decision, not of security. A management team cannot judge on its own whether a certification project is worth its cost. The benefits are diffuse and spread over time. And the person selling the project, often the CISO, is also its beneficiary.

The certification business case is the short document that organizes this judgment. It sets out four things:

- what the certificate would prove, and to whom;
- what it would not prove;
- the effort and the trajectory to obtain it;
- the decision requested.

Its mechanics are those of the business case note written in session 3: honest options, arguments traced to facts, a closed decision. Its limit is the same. A business case does not make the decision, it makes it possible. If management says no, a good business case will still have clarified what the group expects from its security.

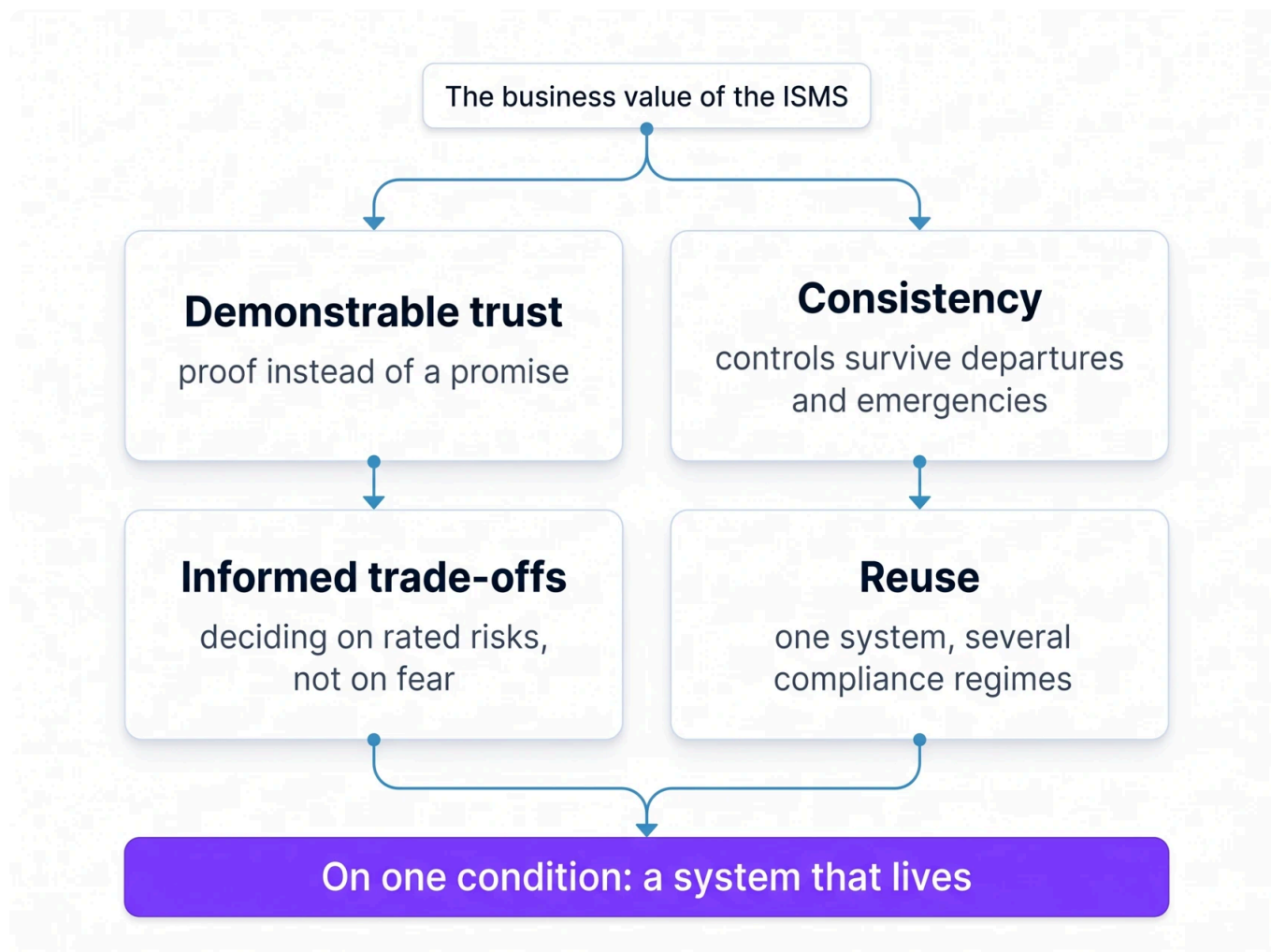
The second notion is the business value of the ISMS. Business value has been familiar since session 2: what counts for the organization in accomplishing its mission. Applied to the management system itself, the question becomes: what does the group gain from keeping an ISMS alive, beyond the CISO's comfort?

The answers fall into four families:

- demonstrable trust: a client, an insurer or a regulator receives a proof instead of a promise;
- constancy: the controls survive departures and emergencies, because a system carries them;

- informed trade-offs: management decides on rated risks and indicators, not on the fear of the last incident;
- reuse: the same system answers several compliance regimes, instead of one initiative per text.

The limit of this value: it materializes only if the system lives. A paper ISMS has a certain cost and zero value. Management knows it by instinct. That is why the business case will have to show a trajectory, not only a certificate.



One market reference to finish, because management will ask for it: ISO 27001 certification remains a small club in France. According to AFNOR, drawing on the international ISO Survey, the country counted a little over a thousand certified organizations at the end of 2023, three times more than in 2019. The momentum was already there in 2020, with increases of 11% in France and 22% worldwide. Translation for the committee: being certified still differentiates, and the growth of the club says contracting authorities are asking for it more and more.

💡 A certification case is judged by its negative sentences. If it contains no "this will not prove", no "this will not cover", it is a sales brochure, and an experienced management will sweep it away with one question. It is for the Group CISO to set the limits, before someone else discovers them instead.

Case study: the third party's requirement that forces the question

Scenario and problem statement

Monday morning, The Managing Director of the subsidiary under review forwards to the Group CISO a requirement received from a third party. The trigger depends on the subsidiary pack. Logistique: the pharmaceutical customer has announced a security questionnaire for the next audit (§3). Éducation: the client schools and municipalities request a compliance attestation each new school year, which the cluster IT Director signs, and none has ever asked for evidence (§2 and §3). Territoires: the delegation contracts, won through public procurement, impose their security clauses (§2 and §3). Santé: the liability insurer is making the renewal of the policy, in the spring, conditional on a security attestation for the HIS, and the Managing Director replied that he would "see with the IT department" (§3). Whatever the trigger, the subsidiary's Managing Director passes the requirement on in the same form, a one-line clause: "The subsidiary shall demonstrate a valid ISO/IEC 27001 certification covering the services provided to this third party, or an equivalent documented approach." The accompanying message holds in one sentence: "Tell me we have this."

The group does not have it. The group chose ISO/IEC 27001:2022 as its reference framework in session 3, imported it into its GRC tool, went through an internal audit in session 4 that left a list of deviations per subsidiary, and has just settled in session 7 a risk treatment plan with its deadlines and its accepted residual risks. An approach therefore exists, real and documented. A certificate does not.

The Chief Executive Officer, informed, frames the CISO's week: "Thursday, at the Executive Committee, I want your recommendation: do we launch a certification effort, on what scope, and what do we answer to this third party in the meantime. No lyricism, facts." This morning's work is to prepare that case.

Guided questions

1. **Analyze** the clause passed on: what exactly does it require, and what is the scope of the words "covering the services provided to this third party" and "or an equivalent documented approach"? At least two readings, with their consequences for the group's answer.
2. **Establish** the "what the certificate would prove" column: to which audiences, taken from the subsidiary pack (§3 and §6), on what object, with what value in light of what session 3 established about what certification attests. Three audiences at minimum, one benefit per audience.
3. **Establish** the symmetrical column, "what the certificate would not prove": three limits at minimum, each in one sentence, including one on regulatory compliance and one on the actual security of the systems.
4. **Propose** a certification scope for the group and defend it in five lines: the whole group, the subsidiary under review alone, or only the services targeted by the third party? Rely on the session 2 mapping and on the deviations found in session 4.

5. **Draft** the decision requested from the Executive Committee, in three sentences at most: the recommendation, what it commits, and the answer proposed to the third party in the interval. Constraint: no certification date promised, no improvised cost.

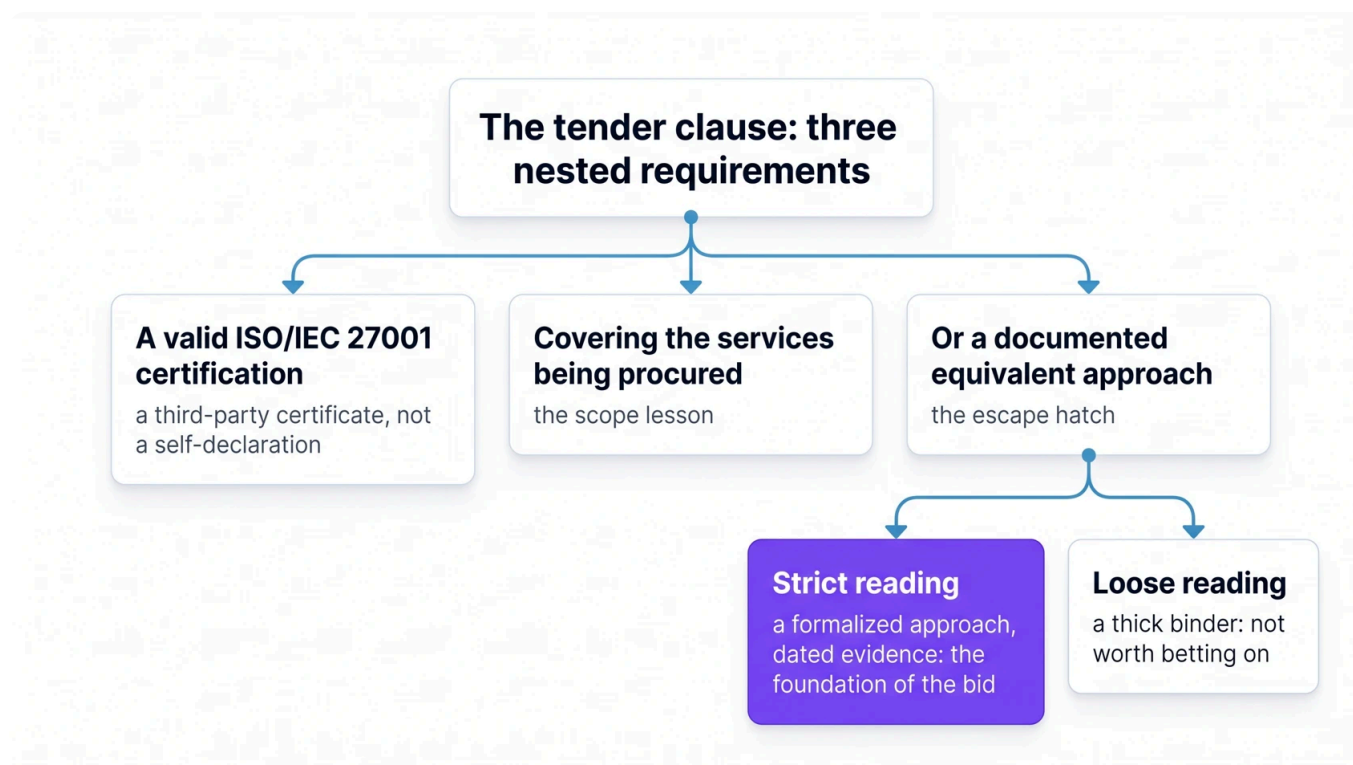
Working method

Allow 5 minutes to reread prior work, 15 minutes for questions 1 to 4, 10 minutes for question 5, which is the only one management will read. Work as in session 3: the fact, then the rule, then the conclusion. And watch out for one precise trap: for each statement, ask whether it describes the group's approach, which exists, or the certificate, which does not. Half of bad certification cases confuse the two, and a client, an insurer or a public buyer will not.

✓ Answer keys and assessment criteria

Reasoned answer key, question by question

Question 1, the clause. It contains three nested requirements. "Valid ISO/IEC 27001 certification": a certificate issued by a third-party body, still valid, so neither a self-declaration nor an internal audit. "Covering the services provided to this third party": this is the scope lesson from session 3; a group certificate that excluded the services the third party receives from the subsidiary under review would not satisfy the clause, and conversely a narrow certificate covering exactly these services would suffice. "Or an equivalent documented approach": the way out, and the object of the real debate. Strict reading: a formalized approach toward certification, with dated evidence, an adopted reference framework, an assessment conducted, a treatment plan settled; the group can document it as of today. Broad reading: any reasonably thick security file; possible, but the group cannot bet its answer on the most lenient reading. Consequence: the answer to the third party is built on the strict reading, with the deliverables of sessions 2 to 7 as supporting documents, and that is already a defensible answer.

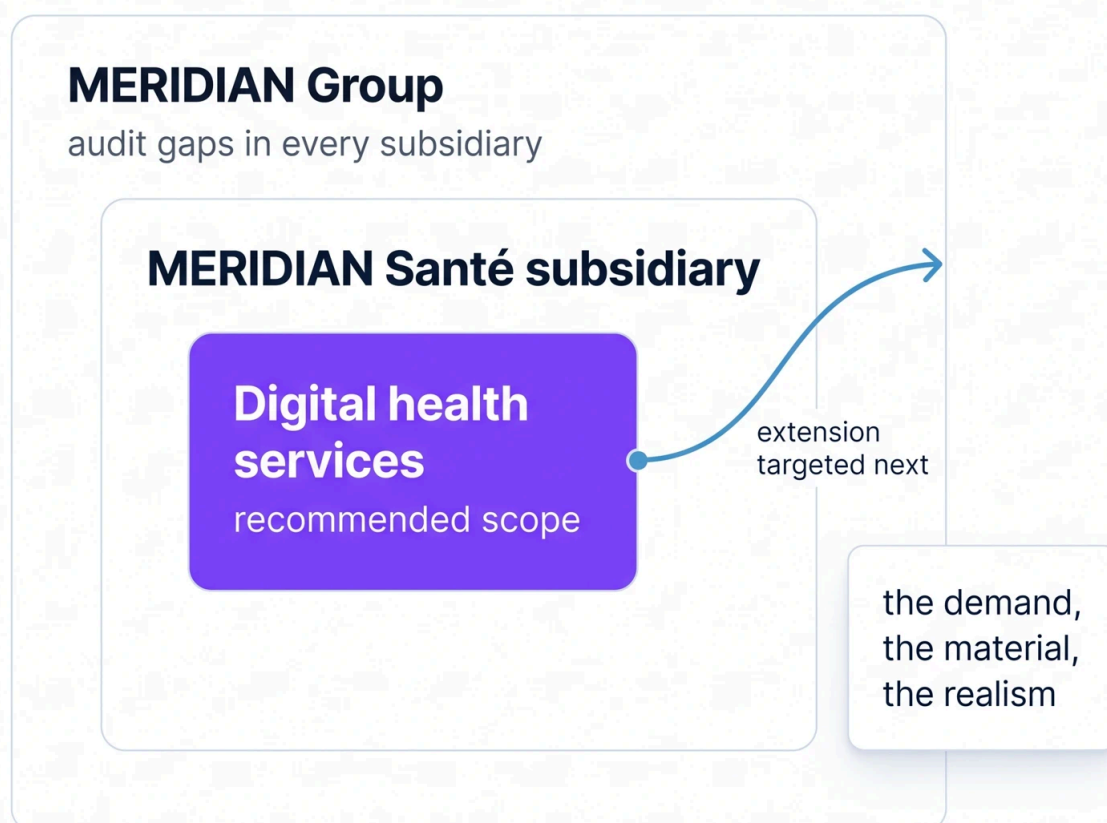


Question 2, what the certificate would prove. To the third party that is asking, and to the other clients or contracting authorities of the subsidiary under review (map of power, §3; boundary, §6): that an accredited third party has verified that the group governs its security according to an international standard, which turns a commercial promise into defensible proof, exactly what the clause passed on is looking for. To management and shareholders: that the security effort undertaken for weeks produces a durable and visible asset, not just expenses; the club remains closed enough for membership to be noticed, a little over a thousand certified organizations in France at the end of 2023 according to AFNOR. To the subsidiaries and the teams: that the group's rules are not a whim of the CISO but a system verified from outside, which moves internal debates from "should we do it" to "how to do it". The regulator will also be accepted as an audience, with the nuance of the next question.

Question 3, what the certificate would not prove. First limit, regulatory: certification does not amount to regulatory compliance, and session 3 established this at the source; official French doctrine grants it no general presumption, only the demonstration of a governance objective over the certified scope. Second limit, operational: the certificate attests a management system, not the absence of vulnerability; an unpatched server can coexist with a valid certificate, and the 2017 Equifax affair remains the most famous reminder of the gap between displayed compliance and actual security. Third limit, scope-related: the certificate proves nothing beyond its scope, and a certificate limited to the subsidiary under review will say nothing about the other three. Any additional honest limit is welcome: the photograph dates from the audit, not from today; upkeep requires a living system, hence a recurring cost.

Question 4, the scope. The most defensible proposal given the group's file: start with the subsidiary under review, and more precisely with the services the third party targets, aiming for a later extension to the group. Three supports. Demand: that is where the pressure exists, the third party's requirement targets these services, and the certificate's scope must cover them to be of use. Material: the session 2 mapping describes the business assets

and supporting assets of the subsidiary under review, with its inter-subsidary dependency from 56 of the subsidiary pack, so that scope can be described without inventing; it does not describe the other three subsidiaries, and a certification scope that cannot be described is a project that goes off the rails. Realism: the findings table of the reference pack shows deviations in all four subsidiaries; treating them everywhere before a group certification would push the certificate beyond the third party's horizon, whereas treating them on the subsidiary under review is a bounded work site, already underway through the session 7 treatment plan. The counter-argument to record honestly: a narrow scope has less display value for the rest of the group, and it will have to be said to the Committee rather than left for it to discover.



Question 5, the requested decision. An example that holds: "I recommend launching the ISO/IEC 27001:2022 certification effort on the scope retained for the subsidiary under review, the services the third party targets, with an extension to the group to be studied next; this commits the continuation of the treatment plan settled in session 7 and a support budget that will be the subject of a separate note. To the third party, we answer as of now under the equivalent documented approach, with as supporting documents our adopted reference framework, our tool-based assessment, our audit report and our dated treatment plan. I ask the Committee to validate these two orientations on Thursday." Three sentences, no certificate date, no invented figure, and the approach/certificate distinction finally serving the group.

Assessment matrix

Criterion	Insufficient	Expected	Excellent
Reading of the clause	Paraphrase, no analysis of the words	The three requirements broken down, two readings of the equivalence	Same, with the consequence of each reading for the group's answer
Balance of the case	Only benefits, or only reservations	Three proofs and three limits, each in a self-contained sentence	Same, each statement traced to something established in sessions 1 to 7
Scope	Not addressed, or decreed without support	A scope proposed, defended by the mapping and the audit deviations	Same, with the narrow-scope counter-argument stated and owned
Requested decision	Vague, or promises of dates and costs	Closed, decidable on Thursday, with no unverifiable commitment	Same, with the interim answer to the third party included
Honesty	The group's approach presented as a quasi-certificate	The approach/certificate distinction held everywhere	Same, and the case states what it cannot yet quantify

The lecture that follows finally opens the standard itself: its architecture, its clauses, and what precisely it requires of management. This morning's case will gain from it what it still lacks: exact knowledge of what the group would be saying yes to.

+200 XP

Formation terminée !